

Cirque Corporation

Information Security Risk Treatment Procedure

Document ID: IS-CIRQ-PR-003-G

Category: Base Policy & ISMS Manual

Division: Procedure

Type: Global

Version: 1.1

Effective Date: July 2025

Review Date: July 2026

Approved By: IT Manager

Generated: March 02, 2026

1. Purpose

The purpose of this procedure is to define the systematic process for selecting and implementing appropriate risk treatment options for information security risks identified by Cirque, in accordance with ISO/IEC 27001:2022 Clause 6.1.3. This ensures that risks are reduced to an acceptable level as defined by Cirque's risk appetite.

****2. Scope****

2. Scope

This procedure applies to all risks identified and evaluated as requiring treatment within Cirque's ISMS scope.

****3. Responsibilities****

3. Responsibilities

- ****IT Manager:**** Accountable for leading the risk treatment process, ensuring Risk Treatment Plans (IS-CIRQ-D-005-G) are developed, implemented, and monitored, and reporting on their status. Also

approves the acceptance of residual risks that are not classified as
\"High.\"

- **Department Managers/Process Owners:** Responsible for implementing risk treatment controls within their respective areas, providing updates on progress, and accepting residual risk.
- **IT Department Personnel:** Responsible for implementing technical controls and providing support for risk treatment activities, leveraging tools such as Windows Defender for Business and Intune.
- **Executive Committee:** Approves significant risk treatment plans and any accepted residual \"High\" risks.
- **Internal Audit Function:** Verifies the implementation and effectiveness of risk treatment controls through monthly internal audits.

4. Procedure

4. Procedure

4.1. Identify Risks Requiring Treatment a. Review the IS-CIRQ-F-001-G: Risk Assessment Register. b. Identify all risks evaluated as \"Medium\" or \"High,\" or any \"Low\" risks that are deemed unacceptable due to Cirque's **low risk appetite**. These risks require a formal treatment plan.

4.2. Select Risk Treatment Options a. For each risk requiring treatment, the IT Manager, in consultation with relevant Department Managers and IT Department Personnel, will evaluate and select the most appropriate risk treatment option(s). Options include: **Modify the risk (Reduce):** Implement controls to reduce the likelihood or impact of the risk. This is the primary focus for Cirque given its low risk

appetite. Examples include: * Implementing new security software (e.g., enhanced EDR, SIEM). * Applying patches and updates (e.g., via Intune). * Strengthening access controls. * Conducting targeted security awareness training. * Improving backup and recovery procedures. * Implementing encryption for sensitive data. * **Retain the risk (Accept):** Accept the risk without further action if it falls within the defined risk acceptance criteria (e.g., a "Low" risk that is impractical or excessively costly to reduce further, and where the IT Manager agrees to accept it). * **Avoid the risk:** Stop the activity or remove the asset that is generating the risk. * **Share or Transfer the risk:** Transfer the risk to another party, e.g., through insurance, or by contractually obliging a third-party service provider to manage specific risks. b. The selected treatment option(s) must align with the IS-CIRQ-P-003-G: Risk Management Policy and Cirque's overall risk appetite.

4.3. Develop Risk Treatment Plan (RTP) a. For each risk (or group of related risks) selected for modification, a detailed Risk Treatment Plan (IS-CIRQ-D-005-G) will be developed. b. The RTP will include: * Identification of the risk. * Selected risk treatment option(s). * Specific controls to be implemented (referencing ISO 27001 Annex A controls where applicable). * Responsible parties for implementation. * Target completion dates. * Required resources. * Metrics for measuring effectiveness (if applicable). c. The IT Manager is responsible for developing the RTP in collaboration with relevant stakeholders.

4.4. Implement Risk Treatment Plan a. Responsible parties identified in the RTP will implement the agreed-upon controls and actions within the specified timelines. b. Progress will be regularly monitored by the IT Manager, leveraging monitoring data from **Windows Defender** for

Business and Intune** where applicable for security control status and risk posture. c. Any deviations from the plan or delays must be communicated to the IT Manager for review and adjustment.

****4.5. Assess Residual Risk**** a. Once risk treatment actions have been implemented, the IT Manager will reassess the risk to determine the ****residual risk**** level (the risk remaining after controls have been applied). b. The reassessment process will follow the methodology outlined in IS-CIRQ-PR-002-G: Information Security Risk Assessment Procedure. c. Record the residual risk in the IS-CIRQ-F-001-G: Risk Assessment Register.

****4.6. Residual Risk Acceptance**** a. If the residual risk is within Cirquel's defined risk acceptance criteria (i.e., \"Low\" as per IS-CIRQ-P-003-G), the risk is accepted. The ****IT Manager** is authorized to approve the acceptance of these \"Low\" and acceptable \"Medium\" residual risks**. b. If the residual risk remains \"High,\" further treatment options must be identified, and the process (from 4.2 onwards) must be repeated until the risk is reduced to an acceptable level or formally accepted by the Executive Committee with documented justification. c. Any residual risk assessed as \"High\" must be formally accepted by the Executive Committee.

****4.7. Statement of Applicability (SoA)**** a. Upon completion of risk treatment and the determination of residual risks, the IT Manager will prepare the IS-CIRQ-D-006-G: Statement of Applicability (SoA). b. The SoA will identify the ISO 27001 Annex A controls selected for implementation, provide justification for their inclusion, and justify any exclusions.

****4.8. Internal Audit Verification**** a. The effectiveness of implemented risk treatment controls and the adherence to this procedure will be

****verified through monthly internal audits**** conducted by the designated internal audit function. Findings from these audits will inform continuous improvement.

****5. Review and Update****

5. Review and Update

a. The effectiveness of implemented risk treatments will be monitored continuously. b. The Risk Treatment Plans and the residual risk levels will be reviewed regularly, especially during the ****quarterly review of high risks**** and as part of the annual ISMS management review. c. This procedure will be reviewed annually or when significant changes occur to the risk management policy or methodology.

****6. Related Documents****

6. Related Documents

- IS-CIRQ-P-003-G: Risk Management Policy
- IS-CIRQ-PR-002-G: Information Security Risk Assessment Procedure
- IS-CIRQ-F-001-G: Risk Assessment Register
- IS-CIRQ-D-005-G: Risk Treatment Plan (RTP)
- IS-CIRQ-D-006-G: Statement of Applicability (SoA)